

FinIA Control - Estado Atual do Sistema

Snapshot técnico de **como o sistema está hoje**, após a rodada de correções do `docs/feedback-backlog.md` (8 blocos) + passada de responsividade/scroll. Complementa o `FINIA_CONTROL_CONTEXT.md` (visão de produto). **Última atualização:** junho/2026.

1. Visão geral da arquitetura

Full-stack **Next.js 16 (App Router)** + **Neon Postgres** + **Drizzle ORM**. Sem API separada - regras de negócio em Server Actions e Server Components.

```
Browser -> Next.js (App Router + Server Actions) -> Neon Postgres
      ^
      |
      | src/proxy.ts (proteção de rotas por sessão)
```

- **Leitura:** Server Components consultam o banco direto (Drizzle).
- **Escrita:** Server Actions (`src/lib/actions/*`), sempre validando `getCurrentUser()`.
- **Autorização:** por sessão (cookie) + checagem de plano/entitlement no servidor.

2. Módulos e status atual

Módulo	Rota	Status	Observações
Autenticação (e-mail+senha)	<code>/login</code> , <code>/cadastro</code>	[OK]	scrypt, sessão httpOnly assinada
Verificação de e-mail	<code>/verificar-email</code>	[OK]	token 24h, reenvio com rate-limit
Recuperação de senha	<code>/esqueci-senha</code> , <code>/redefinir-senha</code>	[OK] novo	token 1h, anti-enumeração, invalida sessões
Onboarding	<code>/onboarding</code>	[OK]	1 tela, estado "Salvando..."
Dashboard	<code>/dashboard</code>	[OK]	projeção correta, alertas, saúde financeira
Receitas	<code>/receitas</code>	[OK]	tabela paginada + CRUD por modal
Despesas	<code>/despesas</code>	[OK]	tabela paginada + CRUD por modal
Metas	<code>/metas</code>	[OK]	tabela paginada + concluir/reabrir meta

Dívidas	/dividas	[OK]	CRUD (cards) - gating server-side
Emprestei	/emprestei	[OK] mudou	oculto por padrão; liberado por usuário pelo admin
Investimentos	/investimentos	[em breve] placeholder	gating Plus server-side
Relatórios	/relatorios	[em breve] placeholder	gating Plus server-side
Assistente IA	/ia	[em breve] placeholder	gating Premium server-side
Configurações	/configuracoes	[OK]	perfil, troca de senha, avatar
Admin	/admin	[OK]	gestão de clientes, planos, entitlement Emprestei

Resiliência: todas as rotas têm `error.tsx` / `loading.tsx` / `not-found.tsx` (raiz e dentro do shell (`app`)), além de `global-error.tsx`.

3. Modelo de dados (tabelas)

Schema em `src/lib/db/schema.ts`. Migrações em `drizzle/` (0000-0010).

Tabela	Colunas relevantes (novas em negrito)
users	id, name, email, password_hash, email_verified, mode, onboarding_complete, plan, role, loans_enabled , created_at
sessions	id (token), user_id, expires_at
email_verification_tokens	id (token), user_id, expires_at
password_reset_tokens	id (token), user_id, expires_at - migração 0007
profiles	user_id, profession, fixed_monthly_income, avatar_webp, ...
incomes	id, user_id, label, amount, type, day_of_month, end_date · índice (user_id, created_at)
expenses	id, user_id, name, amount, category, type, day_of_month, expense_date, installment_count, payment_start_date · índices (user_id, created_at) e (user_id, type)
expense_categories	id, user_id, name
debts	id, user_id, name, balance, monthly_payment · índice (user_id, created_at)

goals	id, user_id, name, target_amount, current_amount, completed (migração 0009) · índice (user_id, created_at)
loans	id, user_id, borrower_name, principal_amount, ..., status · índice (user_id, created_at)
loan_payments	id, loan_id, user_id, paid_at, amount, payment_type · índices em loan_id e user_id

Migrações

Arquivo	O que faz
0000-0006	schema base (init, verificação, planos, avatar, despesas, loans, role)
0007	tabela password_reset_tokens
0008	índices (user_id, created_at) + (user_id, type) em expenses + índices em loan_payments
0009	coluna goals.completed
0010	coluna users.loans_enabled

As migrações 0007-0010 **já foram aplicadas no Neon atual**. Para aplicar SQL via driver HTTP do Neon (o `drizzle-kit migrate` trava com o driver serverless), use `node scripts/apply-sql.mjs drizzle/<arquivo>.sql`.

4. Planos e entitlements

`src/lib/plans/features.ts` - gating por plano (rank `free < plus < premium`):

Recurso	Plano mínimo
dashboard básico, receitas, despesas	free
metas, dívidas, investimentos, relatórios, projeções, próximos vencimentos	plus
assistente IA, alertas inteligentes	premium

- **Gating é server-side** (`PlanLockedScreen` / `hasPlanAccess` antes de buscar dados). O conteúdo protegido **não é renderizado nem enviado** ao cliente (não é mais blur removível).
- **Emprestei NÃO é mais recurso de plano**. Virou **entitlement por usuário** (`users.loans_enabled`), liberado individualmente pelo admin. Oculto no menu, rota bloqueada, fora da landing. Sem limite de pessoas. Admins têm sempre liberado.
- Admin tem **plano efetivo "premium"** por role (sintético) - por isso, nas métricas do painel, admins entram na categoria **"Equipe"**, fora da distribuição de planos.

5. Segurança

Item	Implementação
Hash de senha	scrypt (<code>src/lib/auth/password.ts</code>)
Sessão	token opaco em <code>sessions</code> , cookie <code>httpOnly</code> assinado com <code>HMAC (SESSION_SECRET)</code>
Prefixo de cookie	<code>__Host-finia_session</code> em produção (Secure/Path/sem Domain); <code>finia_session</code> em dev
Rate-limit	<code>src/lib/auth/rate-limit.ts</code> - login, cadastro, reenvio e reset (por IP+e-mail)
Troca de senha	invalida todas as outras sessões (mantém a atual)
Reset de senha	token 1h de uso único, anti-enumeração (resposta genérica), invalida sessões
Avatares	<code>/api/avatar/[userId]</code> exige sessão (não é mais público)
Validações	dia do mês 1-31, valores > 0, nomes únicos (metas), <code>try/catch</code> nas mutations

[!] **Pendências de segurança conhecidas** (médias/baixas, não bloqueantes): TOCTOU nos limites de plano (M2 - precisa enforcement no banco), enumeração no cadastro (M15 - tradeoff de UX). Documentadas no `feedback-backlog.md`.

6. Padrões de UI/UX

- **Tabela única paginada** (`src/components/app/resource-table.tsx`): usada em receitas/despesas/metast. Criar/editar/excluir por `modal`, paginação server-side (`LIMIT/OFFSET` + `count`), filtro por tipo via querystring, linha acessível por teclado.
- **Agregados em SQL** (`src/lib/finance/summary.ts`): StatCards, categorias e próximos vencimentos calculados com `SUM/GROUP BY` (não carrega todas as linhas).
- **Scroll padronizado**: scrollbar de marca aplicada em todo o sistema (`@layer base` no `globals.css`); modais/sheets com `max-height` + scroll interno + `overscroll-contain`; `scrollbar-gutter: stable` no viewport principal.
- **Responsividade**: breakpoints `lg` nas grades de StatCards (tablet/notebook); conteúdo do app centralizado em `max-w-[1400px]`; landing dark fixo.
- **a11y**: `prefers-reduced-motion` global, `role="alert"` nos erros de formulário, navegação por teclado nas tabelas.

7. Ambientes e deploy (Vercel + Neon)

Ambiente	Branch	Domínio	Público
Produção	main	finiacontrol.com.br	clientes
Teste/Staging	staging	finiacontrol.vercel.app	testes

- Vercel: domínio `finiacontrol.vercel.app` conectado ao environment **Preview** (branch `staging`).
- **Variáveis de ambiente** (Vercel, por ambiente):
- `DATABASE_URL` - connection string do Neon (preferir endpoint `-pooler`)
- `SESSION_SECRET` - segredo forte (obrigatório em produção)
- `NEXT_PUBLIC_APP_URL` - base para links de e-mail (deve diferir por ambiente)
- `RESEND_API_KEY`, `EMAIL_FROM` - envio de e-mail

[!] **Pendências de ambiente** (a configurar): banco Neon **separado para staging** (hoje pode compartilhar a produção), `noindex` no domínio de teste, e `NEXT_PUBLIC_APP_URL` distinto por ambiente.

8. Scripts

Comando	Descrição
<code>npm run dev</code>	Servidor de desenvolvimento
<code>npm run build</code>	Build de produção
<code>npm run db:generate</code>	Gera migração a partir do schema
<code>npm run db:migrate</code>	Aplica migração (driver serverless - pode travar)
<code>node scripts/apply-sql.mjs <arquivo.sql></code>	Aplica SQL direto no Neon via HTTP (alternativa confiável)

9. Pendências do backlog (não feitas, por decisão)

Itens de baixa/média prioridade que envolvem lógica financeira sensível ou tradeoffs, documentados no `docs/feedback-backlog.md`:

- **A4** - juros inconsistente no `interest_only` (`countMonthsInclusive` infla ~1 mês)
- **M2** - TOCTOU nos limites de plano (requer enforcement no banco)
- **M10** - selo "em breve" no menu para placeholders
- **M15** - enumeração no cadastro · **A3** - datas como `text`
- **Long tail B2-B10** - arredondamento de parcelas, ordenação na virada do ano, etc.